

ESPE

UNIVERSIDAD DE LAS FUERZAS ARMADAS

INNOVACIÓN PARA LA EXCELENCIA

DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

DESARROLLO SOFTWARE SEGURO

PROYECTO INTEGRADOR DEL PRIMER PARCIAL

Backend: Autenticación JWT/RBAC y detección de esteganografía

Fecha de entrega: 04/11/2026

Resumen

Resumen. La primera entrega del Proyecto Integrador tiene por finalidad diseñar, implementar y evaluar el backend inicial de una aplicación de salas de chat seguras. El producto exigido consta de dos microservicios REST independientes: uno de autenticación y autorización que administra usuarios, roles y su relación muchos a muchos (N:M), emite tokens JSON Web Token (JWT) y aplica control de acceso basado en roles (RBAC); y otro de detección de esteganografía que valida y analiza imágenes exclusivamente después de comprobar la identidad y la autorización vigente del solicitante. El desarrollo debe aportar código ejecutable, documentación arquitectónica y pruebas reproducibles de seguridad e integración, bajo los enfoques Zero Trust, Secure by Design y Shift Left Security.
Palabras clave: microservicios; JWT; RBAC; control de acceso; esteganografía; desarrollo seguro.

1. Descripción del problema y objetivos

El proyecto integrador general propone el diseño y desarrollo de una plataforma de salas de chat seguras con controles de acceso, protección de comunicaciones y validación de contenido multimedia. Sin embargo, antes de implementar las salas y la mensajería, resulta necesario disponer de servicios de identidad y análisis de archivos que incorporen la seguridad desde su arquitectura. En particular, la autenticación debe distinguirse de la autorización: un JWT válido identifica una sesión o un sujeto, pero no basta por sí solo para demostrar que los permisos del usuario continúan vigentes. Del mismo modo, los archivos recibidos de clientes externos no deben considerarse confiables y requieren validaciones previas a su procesamiento.

La primera versión abordará estas necesidades mediante una separación explícita de responsabilidades. AUTH centralizará la administración de identidades y las decisiones RBAC a partir de una base de datos relacional, mientras que STEGO recibirá y examinará archivos de imagen sin acceder directamente a las tablas de identidad. Dicha separación deberá limitar privilegios, reducir acoplamiento y permitir comprobar que la modificación o revocación de roles produce efectos inmediatos en las nuevas solicitudes protegidas. El diseño tomará como referencias los principios de ISO/IEC 27001 e ISO/IEC 27034, sin afirmar certificación ni cumplimiento normativo integral [1, 2].

1.1 Objetivo general

Diseñar, implementar, integrar y evaluar **dos microservicios independientes** que constituyan el Backend V1 de una aplicación de chat segura: un microservicio de autenticación y autorización mediante JWT y RBAC, fundamentado en las entidades persistidas `users`, `roles` y `user_roles`, y un microservicio de

detección de esteganografía que analice imágenes únicamente después de validar las credenciales y los privilegios vigentes del usuario.

1.2 Objetivos específicos

El desarrollo deberá demostrar que el equipo es capaz de modelar una relación de **muchos a muchos (N:M)** entre usuarios y roles; implementar credenciales protegidas, JWT firmados y decisiones de autorización basadas en los datos actuales; exponer una API de análisis de imágenes que ejecute al menos una técnica de detección esteganográfica verificable; diseñar la integración segura entre servicios sin compartir indebidamente las tablas o credenciales de AUTH; y documentar pruebas funcionales, de seguridad y de integración relacionadas con los riesgos identificados.

1.3 Alcance de la primera versión

La primera entrega **no comprende** la interfaz web o móvil, la creación y administración de salas, la mensajería en tiempo real, el cifrado de extremo a extremo del chat ni la restricción de dispositivos de los participantes. Estas características corresponden a etapas posteriores del proyecto general. En consecuencia, la evaluación se limitará al funcionamiento seguro de los dos microservicios, sus interfaces, la persistencia necesaria y la evidencia reproducible de su integración.

2. Indicaciones técnicas y de desarrollo

2.1 Arquitectura e independencia de servicios

La solución deberá organizarse en dos aplicaciones backend con procesos de ejecución, archivos de configuración, endpoints y documentación independientes. Podrán implementarse con el mismo lenguaje o con tecnologías diferentes, siempre que la selección resulte justificada. La implementación de dos carpetas dentro de una sola aplicación no satisfará el requisito arquitectónico: **AUTH y STEGO deberán iniciarse, detenerse y desplegarse de manera autónoma**. Para facilitar su evaluación, ambos servicios deberán estar definidos mediante contenedores separados en `Docker Compose`. Una base de datos o un volumen de almacenamiento se considerarán infraestructura de apoyo, no un tercer microservicio.

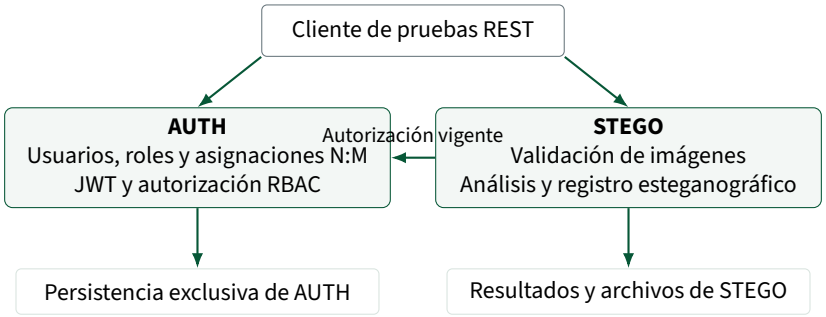


Figura 1: Separación de responsabilidades y comunicación entre los dos microservicios.

2.2 Microservicio de autenticación y autorización (AUTH)

AUTH será la **única autoridad encargada de administrar las identidades y roles**. Su modelo de datos incluirá las entidades `users` (identificador, nombre de usuario, correo electrónico, hash de contraseña, estado y datos de auditoría), `roles` (identificador, nombre, descripción y estado) y `user_roles` (identificador, referencias a usuario y rol, y fecha de asignación). Se implementará una relación N:M mediante claves foráneas hacia las dos entidades principales y una restricción `UNIQUE(user_id, role_id)` que evite duplicaciones. Un mismo usuario podrá recibir varios roles y un mismo rol podrá asignarse a distintos usuarios.

El inicio de sesión validará las credenciales contra los usuarios persistidos, cuyas contraseñas deberán

almacenarse con Argon2id o bcrypt. Los JWT deberán estar firmados, poseer tiempo de expiración acotado y contener un identificador de usuario en `sub`. El equipo documentará el algoritmo autorizado, la gestión de claves y los controles sobre firma, emisor, audiencia y vigencia, tomando como referencia las buenas prácticas correspondientes [5, 7]. Se recomienda emplear firma asimétrica, conservando la clave privada únicamente en AUTH y permitiendo a STEGO verificar tokens con la clave pública.

La autorización RBAC se resolverá **consultando los usuarios, roles y asignaciones vigentes**, no mediante listas de usuarios o permisos codificadas en el código ni confiando exclusivamente en roles incluidos en un JWT antiguo. Las operaciones administrativas serán exclusivas del rol `ADMIN`; el rol `ANALYST` podrá ejecutar análisis y consultar sus resultados autorizados; y el rol `USER` sólo podrá acceder a su perfil y a las operaciones expresamente habilitadas. Un usuario podrá acumular roles, pero cada operación estará sujeta al principio de mínimo privilegio. La eliminación o desactivación de una asignación deberá impedir nuevas operaciones que requieran ese permiso, incluso si el JWT aún no ha expirado.

2.3 Microservicio de detección de esteganografía (STEGO)

STEGO implementará una API REST independiente para recibir archivos de imagen mediante `multipart/form-data`, validar extensión, firma real, tipo de contenido, tamaño y límites de procesamiento, y ejecutar al menos una técnica verificable de detección de posibles datos ocultos. Como alcance mínimo se trabajará con imágenes **PNG o BMP** compatibles con la técnica seleccionada, por ejemplo un análisis estadístico del bit menos significativo (LSB). El equipo deberá justificar el procedimiento y sus parámetros, implementar los cálculos correspondientes y emplear muestras originales y modificadas para evidenciar sus resultados.

La clasificación deberá distinguir, según la evidencia, archivos `sin_indicios`, `sospechosos`, `no_concluyentes` o con `error`. Un resultado sospechoso constituye un **indicio**, no prueba definitiva de esteganografía. Cada análisis conservará al menos un identificador, el usuario solicitante, el hash SHA-256 del archivo, la técnica ejecutada, los indicadores calculados, la fecha, el resultado y la política aplicada (rechazo, cuarentena o advertencia). Los archivos deberán tratarse sin ejecutar código recibido, evitando su exposición pública y controlando su eliminación o aislamiento [4].

2.4 Comunicación segura y aplicación de RBAC

El cliente se autenticará contra AUTH y recibirá un JWT; a continuación, enviará ese token en la cabecera `Authorization: Bearer` de las solicitudes dirigidas a STEGO. Este último comprobará la validez criptográfica del token y solicitará a AUTH, mediante un endpoint interno protegido, una **decisión de autorización actual** para la acción y, cuando corresponda, el recurso solicitado. AUTH verificará el estado del usuario y sus roles persistidos y responderá con una decisión de permitir o denegar. La identidad de STEGO ante AUTH deberá protegerse mediante autenticación entre servicios y un canal seguro. En caso de indisponibilidad de AUTH o de ausencia de una decisión verificable, STEGO rechazará la operación sin procesar el archivo.

El uso de JWT no exime a ningún servicio de la autorización. Por diseño, STEGO **no consultará directamente la base de datos de AUTH**, no almacenará contraseñas ni recibirá la clave privada de firma. Tampoco deberá aceptar permisos proporcionados por el cliente en cabeceras o campos que puedan manipularse. Estos controles materializan los principios Zero Trust y Secure by Design; las pruebas tempranas de credenciales, autorización y archivos reflejarán Shift Left Security [8, 3].

2.5 Contrato mínimo de las APIs

La tabla siguiente sintetiza las rutas requeridas. Se aceptarán prefijos de versión como `/api/v1` si se documentan claramente y se mantienen las responsabilidades asignadas.

Servicio	Método	Ruta	Acceso requerido
AUTH	POST	`/api/auth/login`	Público, con limitaciones
AUTH	GET	`/api/auth/profile`	Usuario autenticado

Servicio	Método	Ruta	Acceso requerido
AUTH	POST	`/api/auth/logout`	Sesión autenticada
AUTH	POST/GET	`/api/users`	ADMIN
AUTH	PATCH	`/api/users/:id`	ADMIN
AUTH	POST/GET	`/api/roles`	ADMIN
AUTH	PATCH	`/api/roles/:id`	ADMIN
AUTH	POST	`/api/user-roles`	ADMIN
AUTH	DELETE	`/api/user-roles/:id`	ADMIN
AUTH	POST	`/internal/authorization/check`	Sólo STEGO autenticado
STEGO	POST	`/api/steganography/analyze`	ADMIN o ANALYST
STEGO	GET	`/api/steganography/results/:id`	RBAC y propiedad del recurso

La API deberá devolver respuestas coherentes y códigos HTTP apropiados: `401` cuando falte o no sea válida la autenticación, `403` cuando el usuario carezca del permiso, `413` para cargas excesivas y `415` para formatos no admitidos. Se deberán registrar los eventos relevantes sin divulgar contraseñas, claves o JWT completos. Todos los endpoints se documentarán con OpenAPI y serán verificables con Postman, Insomnia o herramientas equivalentes.

3. Entregables y presentación de resultados

La entrega comprenderá **un repositorio de código fuente** que contenga ambas aplicaciones backend separadas, sus dependencias, configuraciones de ejemplo y archivos de construcción. Deberán incluirse un `README.md` con las instrucciones para clonar, configurar e iniciar los servicios; un archivo `.env.example` para cada aplicación sin secretos reales; migraciones o scripts para preparar la base de datos de AUTH; y un archivo `docker-compose.yml` que permita levantar los dos microservicios de manera reproducible. La base de datos y el almacenamiento deberán persistir la información necesaria sin comprometer las credenciales del sistema.

La documentación técnica deberá incorporar **un diagrama de arquitectura** que identifique los límites de confianza, las responsabilidades y la comunicación entre AUTH y STEGO, junto con **un diagrama entidad–relación** que muestre la asociación N:M entre `users`, `roles` y `user_roles`. También se entregará una explicación de la autenticación JWT, la autorización RBAC y la estrategia utilizada para comprobar roles vigentes; una matriz de roles y permisos; las especificaciones OpenAPI de ambos servicios; y la justificación técnica del método de análisis esteganográfico, sus formatos y limitaciones.

Como evidencia de desarrollo seguro, los equipos presentarán una **matriz de activos, amenazas, vulnerabilidades, riesgos y controles**, vinculada con los enfoques Zero Trust, Secure by Design y Shift Left Security y con los principios pertinentes de ISO/IEC 27001 e ISO/IEC 27034. Se adjuntarán resultados reproducibles de pruebas unitarias, funcionales, de seguridad e integración, una colección de solicitudes REST, muestras de imágenes sin modificaciones conocidas y con información oculta mediante una técnica compatible, así como registros de auditoría depurados de información sensible.

Durante la sustentación será necesario **ejecutar ambos servicios** y demostrar que cada uno responde desde su propia API. El equipo deberá crear un usuario con dos roles, asignar un rol a dos usuarios, iniciar sesión en AUTH y emplear el JWT recibido para efectuar una solicitud a STEGO. A continuación, deberá demostrar que las solicitudes sin token, con token inválido o sin privilegios son denegadas; que retirar un rol vigente impide una nueva operación con el mismo JWT aún no expirado; y que STEGO falla de manera segura cuando AUTH no puede proporcionar una autorización válida. Finalmente, se analizará una imagen de referencia y una imagen de prueba con datos ocultos compatibles con el detector, explicando los resultados reales y las limitaciones observadas.

Recepción y fecha de entrega. El trabajo se entregará el **miércoles 4 de noviembre de 2026, a la hora de clases**. El equipo deberá presentar el repositorio, la documentación y las evidencias requeridas, y demostrar el funcionamiento del Backend V1 durante la sesión. No se considerará completa una solución monolítica presentada como dos carpetas, ni una detección de esteganografía simulada sin procesamiento de archivos real.

4. Rúbrica de evaluación

La evaluación se efectuará sobre una **calificación máxima de 20 puntos** y considerará la implementación funcional, la seguridad efectivamente aplicada, la calidad del diseño y la reproducibilidad de las evidencias. Se revisará tanto la ejecución de los microservicios como su código fuente, documentación y resultados de prueba. La distribución de puntajes se presenta en la Tabla 2.

N.°	Criterio y evidencia verificable	Puntos
1	**Arquitectura.** Separación real entre AUTH y STEGO, despliegue independiente, contratos REST y Docker Compose.	3,0
2	**Modelo de identidad.** CRUD de usuarios y roles, asociación N:M mediante `user_roles`, claves foráneas y unicidad.	3,0
3	**Autenticación JWT.** Validación de credenciales, hashing de contraseñas, firma, expiración y verificación de tokens.	3,0
4	**RBAC e integración.** Autorización vigente desde AUTH, permisos por rol, denegación 401/403, prueba de revocación y fallo seguro.	4,0
5	**Detección de esteganografía.** Validación y procesamiento real de imágenes, técnica justificada, resultados, alertas o política y auditoría.	5,0
6	**Pruebas y documentación.** OpenAPI, evidencias reproducibles, muestras, matriz de riesgos, guía de ejecución y sustentación.	2,0
	TOTAL	**20,0**

Cuadro 2: Criterios de calificación.

Cada criterio se calificará de acuerdo con el nivel de logro demostrado: **excelente** (100 %), **satisfactorio** (75 %), **en desarrollo** (50 %), **insuficiente** (25 %) o **no demostrado** (0 %). El puntaje obtenido resultará de multiplicar la ponderación máxima por el porcentaje correspondiente. Por ejemplo, el criterio de RBAC e integración, con un máximo de cuatro puntos, recibirá tres puntos si alcanza el nivel satisfactorio. La suma de los seis criterios no podrá superar los veinte puntos.

5. Anexos

5.1 Anexo A. Entidades y relación de muchos a muchos

La relación requerida para JWT/RBAC deberá implementarse mediante una tabla asociativa real y restricciones de integridad en la base de datos. No se aceptarán arreglos de roles almacenados exclusivamente en memoria ni asignaciones codificadas como constantes de aplicación. La estructura lógica mínima se resume en la Tabla 3.

Entidad	Atributos y restricciones obligatorias
`users`	`id` (PK), `username` y `email` (únicos), `password_hash`, `status`, `created_at`, `updated_at`.
`roles`	`id` (PK), `name` (único), `description`, `status`, campos de auditoría.
`user_roles`	`id` (PK), `user_id` (FK), `role_id` (FK), `assigned_at` y `UNIQUE(user_id, role_id)`.

Cuadro 3: Modelo mínimo de identidad perteneciente exclusivamente a AUTH.

5.2 Anexo B. Contrato ilustrativo de autorización

La petición interna `POST /internal/authorization/check` será invocada por STEGO con autenticación de servicio y comunicación protegida. AUTH validará nuevamente la identidad del usuario y comprobará sus asignaciones activas antes de responder. El ejemplo siguiente es referencial y debe concretarse en la documentación OpenAPI del equipo.

```
POST /internal/authorization/check
{
  "subject_token": "<JWT_DEL_USUARIO>",
  "action": "steganography.analyze",
  "resource_id": null
}

// Respuesta de AUTH
{
  "subject_id": "<UUID_USUARIO>",
  "action": "steganography.analyze",
  "allowed": true,
  "reason": "active_role_grants_permission"
}
```

Los datos devueltos no deberán interpretarse como una autorización permanente. Cada operación protegida requerirá una decisión válida, y las fallas de comunicación o autenticación entre servicios deberán resolverse con denegación por defecto.

5.3 Anexo C. Contrato ilustrativo de análisis

STEGO recibirá el archivo en su endpoint de análisis mediante una solicitud `POST` con contenido `multipart/form-data`. Después de comprobar JWT y RBAC, ejecutará la técnica elegida y proporcionará un registro verificable. Los valores numéricos del ejemplo siguiente son exclusivamente ilustrativos, no resultados empíricos que deban reproducirse.

```
{
  "analysis_id": "<UUID_ANALISIS>",
  "user_id": "<UUID_USUARIO>",
  "filename": "muestra.png",
  "sha256": "<HASH_DEL_ARCHIVO>",
  "technique": "lsb_statistical_analysis",
  "status": "sospechoso",
  "indicators": {"anomaly_score": 0.82, "threshold": 0.75},
  "action": "cuarentena",
  "limitations": "Resultado indicativo, no concluyente"
}
```

5.4 Anexo D. Escenarios mínimos de prueba

La demostración funcional deberá abarcar los escenarios de la Tabla 4. El equipo podrá ampliar la cobertura según sus riesgos y tecnología, pero no reemplazarla por capturas sin ejecución demostrable.

ID	Escenario	Resultado mínimo esperado
T01	Iniciar y detener AUTH y STEGO por separado.	Procesos y APIs autónomos; integración reproducible.
T02	Autenticar con contraseña válida e inválida.	JWT firmado o rechazo de autenticación.
T03	Consultar STEGO sin JWT, con JWT manipulado o vencido.	Denegación con HTTP 401.
T04	Usuario con rol USER intenta analizar una imagen.	Denegación con HTTP 403.
T05	Asignar dos roles a un usuario y un rol a dos usuarios.	Relación N:M persistida e íntegra.

ID	Escenario	Resultado mínimo esperado
T06	Repetir una asignación usuario–rol.	No se genera una asociación duplicada.
T07	Retirar un rol y reutilizar JWT todavía vigente.	Nueva operación denegada por el permiso revocado.
T08	Dejar AUTH temporalmente inaccesible.	STEGO no procesa sin autorización comprobada.
T09	Analizar imagen original y una muestra con carga LSB.	Métricas, clasificación y limitaciones documentadas.
T10	Subir archivo inválido, corrupto o demasiado grande.	Rechazo seguro, sin procesamiento indebido.
T11	Consultar un análisis ajeno sin autorización.	Acceso denegado según la política de recursos.
T12	Revisar bitácoras de accesos y análisis.	Trazabilidad sin exponer secretos ni JWT completos.

Cuadro 4: Batería mínima de pruebas de autenticación, RBAC, integración y esteganografía.

5.5 Anexo E. Matriz de riesgos de referencia

Como parte del proceso Shift Left Security, el equipo documentará los activos, amenazas y controles previstos desde el diseño. La Tabla 5 proporciona una referencia inicial que deberá adaptarse a los riesgos realmente identificados y a la arquitectura implementada.

Activo	Amenaza	Control esperado
Credenciales e identidades	Suplantación y divulgación	Hash seguro, validaciones y límites de login.
Asignaciones N:M	Elevación de privilegios	Integridad referencial, autorización vigente y revocación.
JWT y claves	Falsificación o fuga	Firma, caducidad, verificación de claims y secreto protegido.
Comunicación AUTH–STEGO	Suplantación de servicio	Identidad de servicio, canal seguro y denegación por defecto.
Archivos e imágenes	Carga maliciosa o análisis evasivo	Validación de archivos, límites y procesamiento aislado.
Resultados y registros	Acceso indebido	RBAC por recurso y auditoría sin datos sensibles.

Cuadro 5: Referencias de riesgos y controles que deberán justificarse en el informe técnico.

6. Bibliografía

[1] International Organization for Standardization (ISO) e International Electrotechnical Commission (IEC). (2022). *ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection—Information security management systems—Requirements*. https://www.iso.org/standard/27001

[2] International Organization for Standardization (ISO) e International Electrotechnical Commission (IEC). (2011). *ISO/IEC 27034-1:2011. Information technology—Security techniques—Application security—Part 1: Overview and concepts*. https://www.iso.org/standard/44378.html

[3] OWASP Foundation. (2025). *Application Security Verification Standard (ASVS), Version 5.0.0*. https://asvs.owasp.org/

[4] OWASP Foundation. (s. f.). *File Upload Cheat Sheet*. OWASP Cheat Sheet Series. https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html

[5] Jones, M., Bradley, J., y Sakimura, N. (2015). *JSON Web Token (JWT)* (RFC 7519). Internet Engineering Task Force. https://www.rfc-editor.org/rfc/rfc7519

[6] Jones, M. (2015). *JSON Web Key (JWK)* (RFC 7517). Internet Engineering Task Force. https://www.rfc-editor.org/rfc/rfc7517

[7] Sheffer, Y., Hardt, D., y Jones, M. (2020). *JSON Web Token Best Current Practices* (RFC 8725). Internet Engineering Task Force. https://www.rfc-editor.org/rfc/rfc8725

[8] Rose, S., Borchert, O., Mitchell, S., y Connelly, S. (2020). *Zero Trust Architecture* (NIST Special Publication 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207